

Definição dos Planos no Nível Operacional

Objetivo da Aula

Compreender a estrutura dos planos operacionais e conhecer o seu papel crucial na capacidade de uma organização de responder a incidentes de segurança da informação e manter a continuidade das operações.

Apresentação

A gestão eficaz de incidentes de segurança da informação e a continuidade de negócios exigem uma abordagem estruturada que inclua a definição de planos operacionais sólidos. Esses planos operacionais desempenham um papel vital na resposta a incidentes, pois são projetados para orientar ações precisas no nível operacional da organização. Nesta aula, exploraremos a definição dos planos operacionais no contexto da continuidade de negócios e da gestão de incidentes de segurança da informação.

A estrutura desses planos operacionais é essencial para garantir que todos os membros da equipe compreendam claramente suas funções e responsabilidades, bem como os procedimentos a serem seguidos em situações de incidente. Esta estrutura compreende vários elementos, desde a introdução, que estabelece o contexto e a razão de ser do plano, até a gestão de recursos, que aborda a alocação de pessoal, tecnologia e instalações para a resposta a incidentes. Cada um desses elementos desempenha um papel fundamental na preparação da equipe para lidar com situações desafiadoras de forma organizada e coordenada.

1. Estrutura dos Planos Operacionais

A gestão eficaz de incidentes de segurança da informação e a continuidade de negócios exigem uma abordagem estruturada que inclua a definição de planos operacionais sólidos. Esses planos operacionais desempenham um papel vital na resposta a incidentes, pois são projetados para orientar ações precisas no nível operacional da organização.

A estrutura destes planos operacionais é essencial para garantir que todos os membros da equipe compreendam claramente suas funções e responsabilidades, bem como os procedimentos a serem seguidos em situações de incidente. Esta estrutura compreende os seguintes elementos:

- **Introdução:**

- A seção de introdução em um plano operacional serve como ponto de partida, oferecendo uma visão geral do plano e definindo seu propósito;
- Estabelece o contexto e a razão pela qual o plano foi desenvolvido, fornecendo clareza sobre sua finalidade.

- **Escopo:**

- O escopo delimita quais sistemas, processos e ativos estão sob a cobertura do plano;
- Fundamental para definir o alcance das ações a serem tomadas durante um incidente, ajudando a equipe a entender quais ativos são críticos e devem ser protegidos.

- **Responsabilidades:**

- Nesta seção, as funções e responsabilidades de cada membro da equipe de resposta a incidentes são claramente definidas;
- Garante que cada indivíduo saiba exatamente o que se espera dele durante um incidente, promovendo uma distribuição eficaz de tarefas e responsabilidades.

- **Procedimentos:**

- A parte dos procedimentos estabelece os passos detalhados a serem seguidos em resposta a incidentes;
- Inclui etapas que abrangem desde a detecção do incidente até a análise, contenção, erradicação e recuperação. Essa seção cria um guia prático que a equipe pode seguir para lidar com incidentes de segurança.

- **Fluxos de comunicação:**

- Os fluxos de comunicação definem como a informação será transmitida durante um incidente;
- Isso inclui a comunicação interna, que envolve a equipe de resposta, e a comunicação externa, que lida com a notificação de partes interessadas e recursos externos;
- A eficiência na comunicação é essencial para uma resposta rápida e coordenada.

- **Lista de contatos:**

- A lista de contatos contém informações de contato de membros da equipe, partes interessadas e recursos externos que podem ser necessários durante um incidente;
- Ter uma lista de contatos atualizada e acessível é crucial para facilitar a comunicação rápida e a colaboração.

- **Recuperação técnica:**

- Esta seção detalha como os sistemas e dados serão restaurados após um incidente;
- Deve incluir a sequência de ações a serem tomadas e os recursos necessários para a recuperação técnica, garantindo que os sistemas voltem a funcionar normalmente.

- **Backup e restauração:**

- Os procedimentos de backup e restauração são descritos aqui. Isso assegura que os dados e sistemas críticos sejam copiados regularmente e que existam procedimentos claros para restaurá-los em caso de perda, de modo que a organização possa continuar suas operações sem interrupções significativas.

- **Gestão de recursos:**

- A gestão de recursos aborda a alocação de recursos, como pessoal, tecnologia e instalações, durante um incidente;
- Deve ser feito com foco na eficiência e na otimização dos recursos disponíveis para garantir que a equipe de resposta tenha os recursos necessários para lidar com a situação.

A estrutura dos planos operacionais é essencial para garantir que uma organização possa responder eficazmente a incidentes de segurança da informação, minimizando o impacto e mantendo a continuidade dos negócios. Cada um desses elementos desempenha um papel fundamental na preparação da equipe para lidar com situações desafiadoras de forma organizada e coordenada.

2. Procedimentos de Resposta a Incidentes

Os procedimentos de resposta a incidentes normalmente envolvem várias etapas para lidar com incidentes de segurança da informação. Estas etapas podem variar em detalhes específicos, mas geralmente seguem um processo padrão, que inclui:

- **Detecção de incidentes:**
 - Esta é a fase inicial, na qual os incidentes são identificados por meio de monitoramento contínuo, alertas de segurança, relatórios de usuários, ou outras fontes. A detecção eficaz é essencial para iniciar a resposta a tempo.
- **Classificação e avaliação:**
 - Os incidentes detectados são avaliados quanto à gravidade, impacto e prioridade. Isso ajuda a equipe de resposta a determinar ações apropriadas e alocar recursos eficientemente.
- **Notificação e ativação:**
 - Após a avaliação, a equipe de resposta é acionada. Isso pode incluir especialistas em segurança da informação, gerenciamento de crises e outras partes relevantes, dependendo da gravidade do incidente.
- **Investigação e coleta de evidências:**
 - Uma investigação aprofundada é conduzida para entender a natureza do incidente, identificar sua origem e determinar seu escopo. Isso geralmente envolve a coleta de evidências, como logs, registros de atividades e outras fontes de dados relevantes.
- **Isolamento e contenção:**
 - Para evitar que o incidente se espalhe ou cause mais danos, medidas de isolamento e contenção são tomadas. Isso pode incluir a desconexão de sistemas afetados, bloqueio de contas comprometidas e outras ações de segurança.
- **Erradicação e recuperação:**
 - Uma vez que o incidente é isolado, a equipe trabalha para eliminar a causa raiz e restaurar a operação normal dos sistemas. Isso pode envolver a remoção de malware, correção de vulnerabilidades e a restauração de dados a partir de backups.
- **Comunicação com partes interessadas:**
 - Durante o incidente, é essencial manter a comunicação com partes interessadas, como clientes, acionistas, reguladores e equipe interna. Isso inclui informar sobre o incidente, seu impacto e as medidas tomadas para mitigá-lo.
- **Relatórios e documentação:**
 - Todas as ações tomadas durante o incidente são documentadas de forma abrangente. Isso é crucial para futuras investigações, relatórios regulatórios e para melhorar a capacidade de resposta a incidentes no futuro.

- **Análise pós-incidente:**

- Após o incidente ter sido resolvido, é feita uma análise pós-incidente para revisar o que aconteceu, identificar lições aprendidas e fazer melhorias no processo de resposta a incidentes.

Estas etapas permitem que as organizações lidem com incidentes de segurança eficazmente, garantindo que todo o processo seja feito corretamente. Isso tudo tem a capacidade de mitigar danos e impactos negativos à organização, por isso é tão importante planejar previamente tudo a ser feito.

3. Recuperação Técnica

No caso de impactos e perdas críticas, é necessário se basear nos procedimentos de resposta a incidentes de segurança da informação. Essa fase visa restaurar os sistemas, dados e recursos de tecnologia da informação afetados durante o incidente, garantindo que a operação normal da organização seja retomada o mais rapidamente possível.

Uma das considerações fundamentais na recuperação técnica é a definição de prioridades. Nem todos os sistemas e dados têm o mesmo grau de importância, e é vital determinar quais devem ser restaurados primeiro. Geralmente, isso envolve identificar sistemas críticos para as operações comerciais ou serviços, bem como dados sensíveis ou regulamentados.

Além disso, a alocação eficaz de recursos técnicos é essencial. A equipe de resposta deve garantir que haja pessoal qualificado, hardware e software necessários para a recuperação. A coordenação com fornecedores e prestadores de serviços também pode ser necessária para obter suporte técnico adicional.

O plano de restauração de sistemas e dados é uma parte fundamental da recuperação técnica. Ele fornece um roteiro detalhado de como os sistemas afetados serão restaurados. Isso pode incluir a reinstalação de sistemas operacionais, a aplicação de patches de segurança, a restauração de backups e a verificação da integridade dos dados.

É importante enfatizar que a recuperação técnica deve ser conduzida de maneira coordenada e organizada. A equipe de resposta a incidentes deve seguir os procedimentos definidos no plano, garantindo que a restauração seja feita com o mínimo de interrupção possível. Além disso, os procedimentos de teste e validação podem ser realizados para garantir que os sistemas restaurados funcionem conforme o esperado.

Em resumo, a recuperação técnica desempenha um papel fundamental na restauração da normalidade após um incidente de segurança da informação. Definir prioridades, alocar recursos técnicos adequadamente e seguir um plano de restauração bem elaborado são aspectos cruciais desse processo, que visa minimizar o impacto dos incidentes e garantir a continuidade das operações.

4. Procedimentos de Backup e Restauração

Os procedimentos de backup são uma parte vital da gestão da segurança da informação e da continuidade de negócios. Eles envolvem a criação e a manutenção de cópias de dados e sistemas críticos, garantindo que, em caso de perda de dados devido a falhas de hardware, erros humanos, ataques cibernéticos ou desastres naturais, a organização possa recuperar informações essenciais e retomar as operações normalmente.

A frequência de realização dos backups varia de acordo com a importância dos dados que precisam ser salvaguardados. Enquanto informações críticas podem necessitar de backups diários, dados menos sensíveis podem ser replicados menos frequentemente. A determinação da frequência dos backups é orientada pelas demandas específicas da organização.

É crucial implementar uma política de retenção de dados que defina o período pelo qual os backups devem ser mantidos. Alguns dados podem requerer preservação a longo prazo, ao passo que outros podem ser descartados após um curto período.

Diferentes tipos de backups, tais como backups completos, diferenciais e incrementais, estão disponíveis e devem ser escolhidos com base nas necessidades individuais da organização. Cada tipo possui vantagens e desvantagens específicas.

Garantir que os backups sejam armazenados em locais seguros, protegidos contra ameaças físicas, como incêndios, inundações e roubo, é fundamental. As opções de armazenamento podem incluir a nuvem, instalações de armazenamento externas e **data centers** secundários.

Para assegurar a confiabilidade dos backups e a eficácia dos procedimentos de restauração, é imperativo realizar testes regulares. Essas simulações práticas auxiliam na identificação de eventuais problemas antes que um incidente real ocorra.

A documentação detalhada dos procedimentos de backup é de suma importância. Essa documentação engloba a descrição minuciosa de como os backups são realizados, onde são armazenados e como a restauração é conduzida. A equipe precisa estar devidamente treinada e familiarizada com esses procedimentos.

Monitorar regularmente o andamento dos backups é uma prática essencial para garantir que eles estejam ocorrendo conforme o planejado. Quaisquer anomalias, falhas ou problemas devem ser prontamente identificados e abordados para evitar lacunas no processo de backup.

Proteger os backups por meio de medidas de segurança, como a criptografia, é fundamental para assegurar a confidencialidade e a integridade dos dados. Isso é especialmente relevante, visto que os backups contêm informações sensíveis que, se não protegidas adequadamente, podem representar riscos de segurança.

Por fim, é importante revisar e ajustar periodicamente a estratégia de backup para garantir que ela continue atendendo às necessidades em constante evolução da organização. As demandas e tecnologias mudam ao longo do tempo, tornando a revisão regular essencial.

Já os procedimentos de recuperação se concentram na restauração de sistemas e dados após a ocorrência de incidentes de segurança, falhas de hardware, desastres naturais ou outros eventos que possam interromper as operações de uma organização.

É fundamental que, diante de um incidente ou desastre que afete os sistemas e dados de uma organização, sejam estabelecidos procedimentos de recuperação eficazes. A preparação para a recuperação envolve diversos aspectos a serem considerados:

- **Priorização de recuperação:** é importante reconhecer que nem todos os sistemas e dados são igualmente críticos para as operações da organização. Portanto, é necessário determinar quais sistemas e dados devem ser restaurados em primeiro lugar, com base em sua importância;
- **Sequência de ações:** os procedimentos de recuperação devem incluir uma sequência de ações claramente definida. Isso abrange a reinstalação de sistemas operacionais, a aplicação de patches de segurança, a restauração de backups e a verificação da integridade dos dados. Ter uma sequência lógica de etapas é essencial para uma recuperação eficaz;
- **Alocação de recursos técnicos:** para garantir que a recuperação seja conduzida com sucesso, é crucial assegurar que haja pessoal qualificado e os recursos técnicos necessários disponíveis. Isso pode envolver a coordenação com fornecedores e prestadores de serviços para obter suporte técnico adicional, quando necessário;
- **Treinamento da equipe:** a equipe responsável pela recuperação deve ser devidamente treinada e estar familiarizada com os procedimentos. A capacidade da equipe em executar as ações de recuperação de maneira eficaz é fundamental para o sucesso do processo;

- **Testes e validação:** realizar testes regulares de recuperação é uma prática vital. Estes testes ajudam a garantir que os procedimentos funcionem conforme o planejado e que os sistemas restaurados operem de maneira correta;
- **Comunicação com partes interessadas:** manter uma comunicação eficaz com partes interessadas, como clientes, reguladores e equipe interna, é crucial durante o processo de recuperação. Eles devem ser informados sobre o progresso e as medidas tomadas;
- **Documentação de ações:** todas as ações realizadas durante a recuperação devem ser documentadas minuciosamente. Essa documentação é essencial para investigações futuras, relatórios regulatórios e para aprimorar os procedimentos de recuperação;
- **Avaliação pós-recuperação:** após concluir a recuperação, é importante realizar uma análise pós-recuperação. Isso envolve revisar o que aconteceu, identificar lições aprendidas e implementar melhorias nos procedimentos de recuperação para situações futuras;
- **Continuidade de negócios:** a recuperação está estreitamente relacionada com a continuidade dos negócios. Os procedimentos de recuperação devem ser alinhados com os planos de continuidade de negócios da organização para garantir que as operações sejam retomadas de maneira eficiente.

A preparação adequada e a implementação de procedimentos de recuperação eficazes são essenciais para garantir que uma organização possa lidar com incidentes e desastres, minimizando o impacto e mantendo a continuidade das operações.

5. Gestão de Recursos

A gestão de recursos envolve a alocação eficaz e estratégica de recursos essenciais para garantir que a organização esteja pronta para responder a incidentes de segurança da informação e manter a continuidade das operações. Os recursos que precisam ser gerenciados incluem pessoal, tecnologia, instalações e outros ativos críticos.

Ter a equipe certa é essencial. Isso inclui identificar e designar membros da equipe de resposta a incidentes com as habilidades e conhecimentos adequados para lidar com diferentes tipos de incidentes. A equipe deve ser treinada e estar pronta para atuar quando necessário.

Além da equipe treinada, é necessário que a organização tenha acesso às ferramentas e tecnologias para detectar, analisar e responder a incidentes. Isso pode envolver a aquisição e manutenção de software de segurança, sistemas de monitoramento e outros recursos

tecnológicos. Muitas vezes isso também envolve a necessidade de instalações adequadas para coordenar a resposta a incidentes.

Em situações de incidentes graves, pode ser necessário coordenar com recursos externos, como agências de aplicação da lei, empresas de consultoria em segurança cibernética ou outras organizações de suporte. A gestão eficaz dessas parcerias é crucial, sendo necessário garantir que haja canais de comunicação eficientes e sistemas de alerta. A capacidade de se comunicar rapidamente com a equipe de resposta, partes interessadas internas e externas, e com os fornecedores de serviços é essencial durante um incidente.

A capacitação da equipe e a realização de exercícios regulares de resposta a incidentes são essenciais para garantir que todos compreendam seus papéis e responsabilidades e estejam preparados para alocar recursos eficazmente. Assim como ter planos de contingência que detalhem como os recursos serão alocados e utilizados em diferentes cenários de incidentes é fundamental. Isso ajuda a garantir que os recursos sejam direcionados da maneira mais eficaz possível.

Considerações Finais da Aula

Em resumo, a estrutura dos planos operacionais desempenha um papel crucial na capacidade de uma organização de responder a incidentes de segurança da informação e manter a continuidade das operações. Os elementos que compõem essa estrutura estabelecem o alicerce para a ação eficaz, desde a identificação do escopo das ações a serem tomadas até a definição de responsabilidades claras e a criação de procedimentos detalhados. Quando todos esses componentes são cuidadosamente elaborados e implementados, a organização está melhor preparada para enfrentar incidentes e manter a resiliência.

Portanto, ao abordar a estrutura dos planos operacionais, é essencial considerar cada um desses elementos e garantir que eles sejam adaptados às necessidades específicas da organização. A gestão de incidentes de segurança da informação e a continuidade de negócios são esforços contínuos, e a estrutura dos planos operacionais é uma peça fundamental desse quebra-cabeça, fornecendo a base para a ação coordenada e eficaz em tempos de desafio.

Material Complementar

Artigo

CERT.br

2024, CERT.

O Centro de Estudos, Resposta e Tratamento de Incidentes de Segurança no Brasil (CERT.br) é um Grupo de Resposta a Incidentes de Segurança (CSIRT) de Responsabilidade Nacional de último recurso, mantido pelo NIC.br.

O NIC.br é uma entidade civil de direito privado e sem fins lucrativos, encarregada da operação do domínio.br, bem como da distribuição de números IP e do registro de Sistemas Autônomos no País. Conduz ações e projetos que são benéficos à infraestrutura da internet no Brasil e implementa as decisões e os projetos do CGI.br, responsável por coordenar e integrar as iniciativas e serviços da internet no país.

O CERT.br é um CSIRT Nacional de Último Recurso, mantido pelo NIC.br, e presta serviços da área de Gestão de Incidentes de Segurança da Informação para qualquer rede que utilize recursos administrados pelo NIC.br.

Disponível em: <https://www.cert.br/>. Acesso em: 2 fev. 2024.

Referências

AZURE. O que é o serviço de Backup do Azure? **Microsoft**, 2023. Disponível: <https://learn.microsoft.com/pt-br/azure/backup/backup-overview>. Acesso 15 de agosto de 2023.

BENZ, K. H. **Alinhamento estratégico entre as políticas de segurança da informação e as estratégias e práticas adotadas na TI**: estudos de caso em instituições financeiras. Dissertação (mestrado) – Universidade Federal do Rio Grande do Sul, Escola de Administração, Programa de Pós-graduação em Administração, 2008. Disponível em: <https://lume.ufrgs.br/handle/10183/12905>. Acesso em: 16 ago. 2023.

PLANEJAMENTO estratégico em tecnologia da informação: um estudo sobre as dificuldades para implantação em uma instituição de ensino superior. **IBICT**, 2016. Disponível em: https://bdtd.ibict.br/vufind/Record/UFBA-2_14506dd17acf9e65bb57551ef4230ee2. Acesso em: 16 ago. 2023.